

Explainable Graph-Based Attack Surface Visibility Scoring Using SIEM Telemetry and Threat Intelligence

Ismet Arslan

Department of Computer Engineering

[University / Institution Name]

[City], Turkiye

[email address or ORCID]

Abstract—Security operations centers collect heterogeneous telemetry from endpoint, network, identity, and application layers; however, many organizations still lack a measurable view of how much of their attack surface is actually observable. This paper proposes an explainable graph-based attack surface visibility scoring model that combines asset inventory, SIEM telemetry, cyber threat intelligence, and MITRE ATT&CK technique mappings in a unified representation. The proposed approach models assets, log sources, alerts, indicators, and adversary techniques as graph nodes, while observation, enrichment, and coverage relationships are represented as typed edges. A weighted scoring function estimates visibility by considering log coverage, critical asset coverage, MITRE detection coverage, threat intelligence enrichment, and telemetry freshness. The model is designed to produce both a numerical visibility score and human-readable explanations that can support SOC analysts, security managers, and audit teams. A proof-of-concept scenario based on Wazuh, Windows Sysmon, Linux authentication logs, and synthetic CTI indicators demonstrates how the model can expose blind spots such as missing critical logs, stale telemetry, and uncovered ATT&CK techniques. The results indicate that graph-based fusion can transform fragmented SIEM evidence into an interpretable security visibility assessment.

Keywords—SIEM, Wazuh, attack surface, threat intelligence, MITRE ATT&CK, graph model, explainable security, SOC maturity

I. INTRODUCTION

Modern security operations centers (SOCs) depend on continuous telemetry collection to detect malicious behavior, investigate incidents, and prioritize response actions. Security information and event management (SIEM) platforms aggregate endpoint, authentication, network, and application logs; nevertheless, the existence of a SIEM deployment does not guarantee operational visibility. A critical server without a functioning agent, a firewall that forwards only a subset of events, or an endpoint whose telemetry has become stale can create blind spots that are not obvious from alert volume alone.

This problem is intensified by the growth of enterprise attack surfaces. Cloud services, remote access platforms, identity providers, endpoints, and third-party integrations create many paths through which adversaries may operate. At the same time, SOC teams often measure activity using alert counts or rule matches rather than explicitly measuring what is observable, what is missing, and how missing telemetry affects adversary technique coverage. As a result,

a high number of alerts may coexist with poor visibility over critical parts of the environment.

This study addresses the following research question: how can heterogeneous SIEM telemetry and threat context be fused into an explainable score that represents attack surface visibility? To answer this question, we propose a graph-based visibility model that connects assets, log sources, alerts, threat indicators, and MITRE ATT&CK techniques. The graph representation makes it possible to reason over direct and indirect relationships, such as which critical assets are monitored, which techniques have observable evidence, and which alerts are enriched by cyber threat intelligence (CTI).

The main contribution of this paper is a practical scoring framework that translates fragmented operational telemetry into an interpretable visibility index. The framework is not intended to replace detection engineering or risk assessment. Instead, it provides an additional layer for measuring whether the current SOC data collection architecture can observe relevant events. The proposed model is designed to be implemented with open-source SIEM data and simple tabular inventories, making it suitable for small and medium-sized organizations as well as academic laboratory environments.

The contributions of this paper are threefold. First, it defines a graph schema for combining assets, SIEM telemetry, CTI indicators, and ATT&CK techniques. Second, it proposes a weighted explainable visibility score based on coverage and freshness metrics. Third, it presents a controlled proof-of-concept scenario showing how Wazuh telemetry can be converted into actionable visibility findings.

II. RELATED WORK

A. SIEM Telemetry and Continuous Monitoring

SIEM systems are widely used to centralize event collection, correlation, and alerting. Continuous monitoring guidance emphasizes that security status should be assessed through ongoing observation of information systems rather than through isolated periodic checks [4]. In practice, this requires not only collecting logs but also validating whether critical assets and security-relevant data sources are consistently represented in the monitoring pipeline.

Open-source SIEM platforms such as Wazuh provide host-based monitoring, rule-based detection, and ATT&CK-related rule metadata. Wazuh documentation describes how rules can include MITRE identifiers, enabling analysts to examine alerts through adversary tactics and techniques [2]. This capability is useful, but it does not automatically answer whether important techniques are covered across the monitored attack surface. The proposed model extends this idea by calculating coverage and freshness across assets and techniques.

B. MITRE ATT&CK and Threat Intelligence

MITRE ATT&CK provides a structured knowledge base of adversary tactics and techniques and includes platforms such as Windows, Linux, macOS, cloud, identity providers, SaaS, network devices, containers, and ESXi in the Enterprise matrix [1]. ATT&CK has become a common reference for detection engineering, threat hunting, and security assessment. Recent reviews highlight its broad adoption and also point to open challenges in operationalizing ATT&CK-based risk and detection coverage assessments [6].

Threat intelligence standards such as STIX and TAXII enable machine-readable representation and exchange of indicators, malware, attack patterns, and related cyber threat objects [3]. CTI can improve the context of SIEM alerts, but its value depends on how indicators and techniques are connected with internal telemetry. A graph model is a natural fit for representing these relationships because it can link internal assets with external intelligence and adversary behavior in a single structure.

C. Graph-Based Cybersecurity Assessment

Cybersecurity knowledge graphs have been studied as a way to aggregate entities, events, vulnerabilities, and threat intelligence for reasoning and decision support. Reviews of knowledge graph applications in cybersecurity indicate their usefulness in representing complex attack and defense relationships [8]. For SOC visibility assessment, graph modeling provides two advantages: it can preserve the provenance of each relationship, and it can explain a score through the nodes and edges that contributed to it.

Existing maturity and scorecard approaches often focus on compliance, control existence, or testing results. ATT&CK-based rating frameworks have been proposed to summarize security assessment outcomes [7]. Our approach differs by focusing on monitoring visibility from SIEM telemetry. Instead of asking only whether an organization has a control, the proposed score asks whether telemetry exists, remains fresh, maps to known techniques, and is enriched with threat context.

III. PROPOSED MODEL

The proposed model contains five logical layers: asset inventory, telemetry ingestion, threat context, graph fusion, and explainable scoring. Fig. 1 summarizes the data flow. Asset inventory provides the list of systems and their criticality levels. Telemetry ingestion receives events from Wazuh agents, Windows Sysmon, authentication logs, network devices, and other sources. Threat context includes ATT&CK technique identifiers and CTI indicators. The

graph fusion layer creates typed relationships among these entities. Finally, the scoring engine computes normalized metrics and generates explanations.

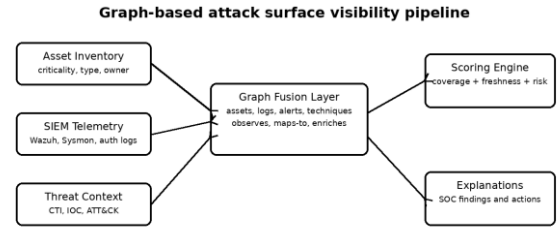


Fig. 1. Proposed graph-based visibility scoring pipeline.

A. Graph Schema

The graph is defined as $G = (V, E)$, where V represents nodes and E represents typed edges. Nodes may correspond to assets, log sources, alerts, indicators, ATT&CK techniques, and detection rules. Edges represent operational relationships such as an asset being observed by a log source, an alert mapping to a technique, or an indicator enriching an event. Each node and edge can carry attributes such as timestamp, confidence, criticality, platform, and source.

In the proposed schema, asset nodes represent endpoints, servers, firewalls, VPN platforms, cloud services, and identity components. Telemetry nodes represent Wazuh alerts, Sysmon events, authentication events, and network logs. Threat nodes represent indicators of compromise, malware families, campaign tags, or threat actor labels when available. Technique nodes represent ATT&CK tactics and techniques. The main edge types are observes, maps-to, enriches, depends-on, and lacks-coverage.

Asset node: monitored or expected enterprise component with type, owner, platform, and criticality attributes.

Telemetry node: event or alert evidence collected from SIEM, endpoint, network, identity, or application sources.

Technique node: ATT&CK tactic or technique connected to rule metadata, analytic logic, or observed evidence.

Threat node: CTI object such as an IOC, malware label, or campaign reference used to enrich alerts.

Negative evidence: missing, stale, or incomplete telemetry relationship used to explain blind spots.

B. Visibility Metrics

Visibility is calculated using normalized metrics in the range $[0,1]$. The default score, denoted as V_s , is computed as a weighted sum:

$$V_s = 100 * (w1LC + w2CAC + w3MDC + w4CTIC + w5TF)$$

Here, LC is log coverage, CAC is critical asset coverage, MDC is MITRE detection coverage, CTIC is CTI enrichment coverage, and TF is telemetry freshness. The weights can be adapted to organizational priorities. In this proof-of-concept, the default weights are $w1=0.30$, $w2=0.25$, $w3=0.20$, $w4=0.15$, and $w5=0.10$.

LC: ratio of assets with fresh logs to total assets in scope.

CAC: ratio of critical assets with fresh telemetry to all critical assets.

MDC: ratio of covered ATT&CK techniques to the selected technique subset.

CTIC: ratio of alerts enriched with threat intelligence to eligible alerts.

TF: ratio of telemetry sources that remain inside the freshness threshold.

C. Explainability Layer

The explainability layer converts graph evidence into concise findings. Instead of presenting only a final score, the model traces the paths that caused score changes. For example, if a critical domain controller is connected to an asset node but has no fresh telemetry edge in the last 24 hours, the explanation is generated as a visibility gap. If an alert maps to credential access but the organization has no detection coverage for adjacent credential techniques, the explanation identifies a partial MITRE coverage gap.

This layer can be implemented through deterministic templates or through a large language model (LLM) controlled by structured input. In this paper, LLM use is treated as optional. The primary contribution is the structured graph and score; natural language generation is used only to transform already computed evidence into analyst-readable text. This design avoids relying on unverified model reasoning for the numerical result.

D. Scoring Procedure

The scoring procedure follows a deterministic pipeline. First, the expected monitoring scope is extracted from the asset inventory. Second, each asset is matched with its most recent telemetry source and a freshness status is calculated. Third, alert metadata and rule mappings are associated with ATT&CK techniques. Fourth, CTI matches are linked to alerts or indicators. Finally, the metric vector is calculated and converted into a final visibility score.

Step 1: Load asset inventory and assign each asset a type, criticality, owner, and expected telemetry source.

Step 2: Normalize SIEM events into asset, timestamp, source, alert, rule, and indicator fields.

Step 3: Build graph nodes for assets, telemetry, alerts, indicators, and techniques.

Step 4: Create observes, maps-to, enriches, and lacks-coverage relationships.

Step 5: Compute LC, CAC, MDC, CTIC, and TF metrics using the graph relationships.

Step 6: Generate explanations from the lowest contributing metrics and negative evidence paths.

IV. PROOF-OF-CONCEPT LABORATORY DESIGN

A controlled laboratory scenario was designed to demonstrate the feasibility of the proposed model without using sensitive production data. The environment uses synthetic and anonymized telemetry objects that mimic typical SOC data sources. The design is intentionally lightweight so that it can be reproduced in academic and small organizational settings.

Wazuh manager: central alert processing, agent status monitoring, and rule metadata collection.

Windows endpoint: Sysmon and security log generation for process creation, DNS query, network connection, and logon events.

Linux server: SSH authentication failures, sudo activity, service logs, and command-related telemetry.

Synthetic CTI list: IP address, domain, hash, technique, and confidence fields for enrichment testing.

Asset inventory CSV: asset type, criticality, business owner, expected log source, and monitoring status fields.

ATT&CK mapping file: selected techniques, tactics, platforms, expected data source, and detection rule references.

A. Telemetry Generation

Windows telemetry is represented with process creation, network connection, DNS query, failed logon, and PowerShell execution events. Linux telemetry is represented with SSH authentication failures, privilege use, and service-related events. These events are sufficient to demonstrate how the model relates telemetry to a limited ATT&CK subset such as command and scripting interpreter, valid accounts, account discovery, and remote services.

The laboratory scenario also contains intentional blind spots. Some assets are present in the inventory but have no recent logs. One critical server is marked as stale because its last-seen timestamp exceeds the freshness threshold. Another asset has authentication logs but lacks endpoint process telemetry. These conditions allow the scoring function to generate meaningful negative findings rather than producing only a positive coverage report.

B. Data Processing Pipeline

The pipeline starts by normalizing asset inventory and telemetry into a common tabular structure. Each asset is assigned an identifier, type, criticality level, and expected telemetry sources. Alerts and events are mapped to the asset identifier when possible. Technique mappings are derived from rule metadata or a manually maintained detection mapping table. CTI enrichment is performed by matching event indicators against a synthetic indicator list containing confidence scores.

The normalized tables are converted into graph edges. An asset with a fresh Wazuh agent status receives an observes edge to the corresponding telemetry source. An alert containing a technique identifier receives a maps-to edge to an ATT&CK technique node. A matched indicator creates an enriches edge between the alert and CTI node. Missing or stale sources create negative evidence that is stored separately and used by the explainability layer.

V. PRELIMINARY RESULTS AND DISCUSSION

The proof-of-concept scenario contains ten assets, including four critical assets. Seven assets have at least one fresh telemetry source, while three assets are missing or stale. The selected ATT&CK subset includes eight techniques relevant to endpoint and authentication telemetry. The model is then executed over the normalized data and produces metric-level scores. These values represent a synthetic laboratory run and should be replaced with operational measurements when the model is deployed in a real SOC environment.

Log coverage: 0.70 with a weighted contribution of 0.210.

Critical asset coverage: 0.75 with a weighted contribution of 0.188.

MITRE detection coverage: 0.625 with a weighted contribution of 0.125.

CTI enrichment coverage: 0.40 with a weighted contribution of 0.060.

Telemetry freshness: 0.80 with a weighted contribution of 0.080.

Final visibility score: 66.3/100 in the synthetic proof-of-concept scenario.

The final visibility score indicates a moderate monitoring posture in the synthetic scenario. The score is not low because most assets still provide at least one telemetry source; however, it is not high because CTI enrichment is limited and the selected ATT&CK subset is only partially covered. The graph also identifies that one critical asset has stale telemetry, which lowers both critical asset coverage and telemetry freshness.

A sample explanation generated from the graph is as follows: 'Visibility is reduced because three assets do not have fresh logs, one of them is critical, CTI enrichment exists for only 40 percent of eligible alerts, and three of eight selected ATT&CK techniques do not have observable evidence in the current telemetry set.' This explanation is directly derived from graph relationships and metric values, making the result auditable.

The model can support several SOC use cases. First, it can be used as a weekly visibility health check to reveal monitoring gaps before an incident occurs. Second, it can help prioritize onboarding of missing log sources by considering asset criticality. Third, it can provide management-level visibility reports without hiding the technical evidence that produced the score. Finally, it can guide detection engineering by showing which ATT&CK techniques are currently observable and which remain blind spots.

A. Limitations

The current proof-of-concept has limitations. The evaluation uses a synthetic and small-scale laboratory scenario rather than production telemetry. Therefore, the numerical values should not be interpreted as a general benchmark. The selected metric weights are also configurable and require organizational calibration. Different sectors may assign more importance to identity telemetry, network telemetry, or endpoint process visibility depending on their threat model.

Another limitation is the dependency on accurate asset inventory and mapping tables. If an organization does not maintain asset criticality or expected telemetry information, the model may underestimate or overestimate visibility. Future work should integrate automatic asset discovery and confidence scoring for inventory quality.

VI. IMPLEMENTATION NOTES

The proposed model can be implemented with a small Python processing layer. Asset inventory and mapping files can be stored as CSV or JSON files, while Wazuh alerts can be exported through the indexer API or scheduled queries. A graph library can then construct relationships and compute metric values. The output can be written back to a dashboard, a report, or a weekly SOC health-check document.

For security and privacy reasons, the model does not require raw production data to be published. Only aggregate

counts, normalized scores, and anonymized examples are needed for academic reporting. This is important for organizations that cannot disclose hostnames, usernames, internal IP addresses, or event details. The same design also makes the model suitable for reproducible laboratory experiments using synthetic telemetry.

VII. CONCLUSION

This paper presented an explainable graph-based model for attack surface visibility scoring using SIEM telemetry and threat intelligence. The proposed approach combines asset inventory, Wazuh alerts, endpoint and authentication logs, CTI indicators, and MITRE ATT&CK mappings into a unified graph representation. A weighted scoring function estimates visibility through log coverage, critical asset coverage, detection coverage, CTI enrichment, and telemetry freshness.

The proof-of-concept scenario demonstrates that graph-based fusion can transform fragmented security evidence into an interpretable visibility assessment. Instead of only reporting alert volume, the model identifies monitored assets, stale telemetry, missing critical logs, and uncovered adversary techniques. Future work will extend the laboratory implementation with larger telemetry sets, automated dashboard generation, real-time graph updates, and systematic comparison with existing SOC maturity assessment methods.

ACKNOWLEDGMENT

This work is prepared as a research draft for an academic conference submission. The laboratory values in the proof-of-concept section are based on synthetic telemetry and should be updated with measured values after the experimental environment is finalized.

REFERENCES

- [1] The MITRE Corporation, "Enterprise Matrix," MITRE ATT&CK. Accessed: Jun. 21, 2026. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>
- [2] Wazuh, "MITRE ATT&CK framework - Data analysis," Wazuh Documentation. Accessed: Jun. 21, 2026. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/ruleset/mitre.html>
- [3] OASIS Cyber Threat Intelligence TC, "STIX Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [4] K. Dempsey, N. Chawla, A. Johnson, R. Johnston, A. Jones, A. Orebaugh, M. Scholl, and K. Stine, "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations," NIST Special Publication 800-137, 2011.
- [5] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0," NIST Cybersecurity White Paper, 2024.
- [6] B. Al-Sada, A. Sadighian, and G. Oligeri, "MITRE ATT&CK: State of the Art and Way Forward," arXiv:2308.14016, 2023.
- [7] H. Manocha, A. Srivastava, C. Verma, R. Gupta, and B. Bansal, "Security Assessment Rating Framework for Enterprises using MITRE ATT&CK Matrix," arXiv:2108.06559, 2021.
- [8] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, "A review of knowledge graph application scenarios in cyber security," arXiv:2204.04769, 2022.
- [9] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in Proc. IEEE Symposium on Security and Privacy, 2010, pp. 305-316.
- [10] V. Mavroudis and S. Bromander, "Cyber threat intelligence model: An evaluation of taxonomies, sharing standards, and ontologies within

cyber threat intelligence," in Proc. 2017 European Intelligence and Security Informatics Conference, 2017, pp. 91-98.

- [11] OASIS Cyber Threat Intelligence TC, "TAXII Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/taxii/v2.1/taxii-v2.1.html>
- [12] M. Ussath, D. Jaeger, F. Cheng, and C. Meinel, "Advanced persistent threats: Behind the scenes," in Proc. 2016 Annual Conference on Information Science and Systems, 2016, pp. 181-186.